Fanatics Decoration QC Lab

Technical, Security & Audit Dossier

Fabric decoration-readiness portal — MVP

Document control	
Owner / author	Digna Julia Herrera — QC Administrator
Audience	Fanatics IT, Information Security, Internal Audit, Global Sourcing Quality
Version / date	1.1 — October 2026
Classification	Internal — Confidential
System	https://fanatics-qc-lab.vercel.app (MVP)
Source code	github.com/djherreralopez95-cmyk/fanatics-qc-lab (private)

Contents

1. Executive summary

The **Fanatics Decoration QC Lab** is a web application that standardizes how fabric lots received from mills are qualified before they go through decoration (screen print, sublimation, spot sublimation, heat transfer, HTV, tackle twill, DTF, DTG, embroidery, pad print, labels, patches, silicone and foil). Mills upload laboratory results and evidence for each lot and each color; a deterministic decision engine applies the Fanatics protocol (AATCC, ISO 105 and ASTM methods plus Fanatics heat-ladder tests) and returns, for every decoration method, a verdict, the **maximum safe decoration temperature** and the **mandatory production conditions** (low-cure ink, bleed blocker, poly white, blocker adhesive, etc.). Fanatics QC reviews and records the final decision.

This dossier describes the business process, architecture, technology providers, data model, security controls, audit trail, operations and known limitations so that Fanatics IT can **audit, approve and, if desired, take ownership** of the solution.

Key facts

Area	Summary
Hosting	Vercel (Next.js application) + Supabase (managed PostgreSQL, Auth, Storage). Fully portable: standard Node.js app and standard PostgreSQL.
Users	Fanatics QC Administrator, Fanatics Technician, Mill (supplier) users. No public sign-up.
Data	Business data only: suppliers, fabrics, lots, test readings, evidence files, users' names and work e-mails. No payment, health or consumer personal data.
Authentication	E-mail + password with mandatory TOTP two-factor authentication (MFA).
Authorization	Role-based access + PostgreSQL Row Level Security: each mill can only see its own company data.
Audit	Append-only, hash-chained audit log of every change, verifiable with one SQL query.
Integrations	Read-only REST API (JSON/CSV) for Power BI/Excel, read-only SQL schema `bi`, read-only MCP server for AI agents.
Status	MVP: functional, tested (unit, database security and end-to-end tests). Production hardening items are listed in section 14.

2. Business context and process

Dark and saturated polyester fabrics are prone to **dye migration** (sublimation of disperse dyes into white inks, twill and labels under heat). Decisions on whether a fabric can be decorated, and how, were previously made case by case. The QC Lab turns this into a documented, repeatable and auditable process.

2.1 End-to-end flow

1. **Supplier onboarding** — the QC Administrator registers the mill (logo, contacts, tier) and creates its user accounts.
2. **Fabric registration** — the mill registers each fabric article (fiber family, composition, construction, weight, dye class, photo).
3. **Lot submission** — the mill submits a lot: lot/dye-lot number, PO, program, garment type, **colors to be tested** and the decoration methods the lot must qualify for. Fanatics QC is notified (in-app and e-mail).
4. **Testing and evidence** — results are entered per test and per color (gray-scale grades 1–5, spectrophotometer ΔE, or instrument values) with photos, lab PDF reports and spectro files.
5. **Engine evaluation** — the engine computes pass/fail per reading, the max safe temperature, a verdict per decoration method and a suggested lot status. Each color is evaluated separately; the lot takes the worst color.
6. **Review and decision** — the Technician/Administrator reviews the dossier, may override a method verdict with justification, and records the decision: Approved, Approved with concession, Retest, On hold or Rejected. The mill is notified.
7. **Garment verification** — a finished, decorated garment is washed (e.g. 25 cycles) and rated with before/after photos; a failure downgrades the decoration method.
8. **Corrective action (CAPA)** — rejected or retest lots open a CAPA automatically; the mill documents root cause and actions, Fanatics accepts or returns it, and an approved retest lot closes it.
9. **Dossier and reporting** — a printable decoration-readiness dossier is generated; dashboards show Right First Time, approval rate, cycle time and failure Pareto per supplier.

2.2 Roles

Role	Who	Purpose
QC Administrator	Fanatics (Digna Julia Herrera)	Owns the system: users, suppliers, protocol minimums, API keys, audit log, decisions.
Fanatics Technician	Fanatics (Gabriel)	Responsible for test methods; reviews results and records decisions.
Supplier	Mill quality users	Registers fabrics, submits lots, uploads results and evidence for their own company only.

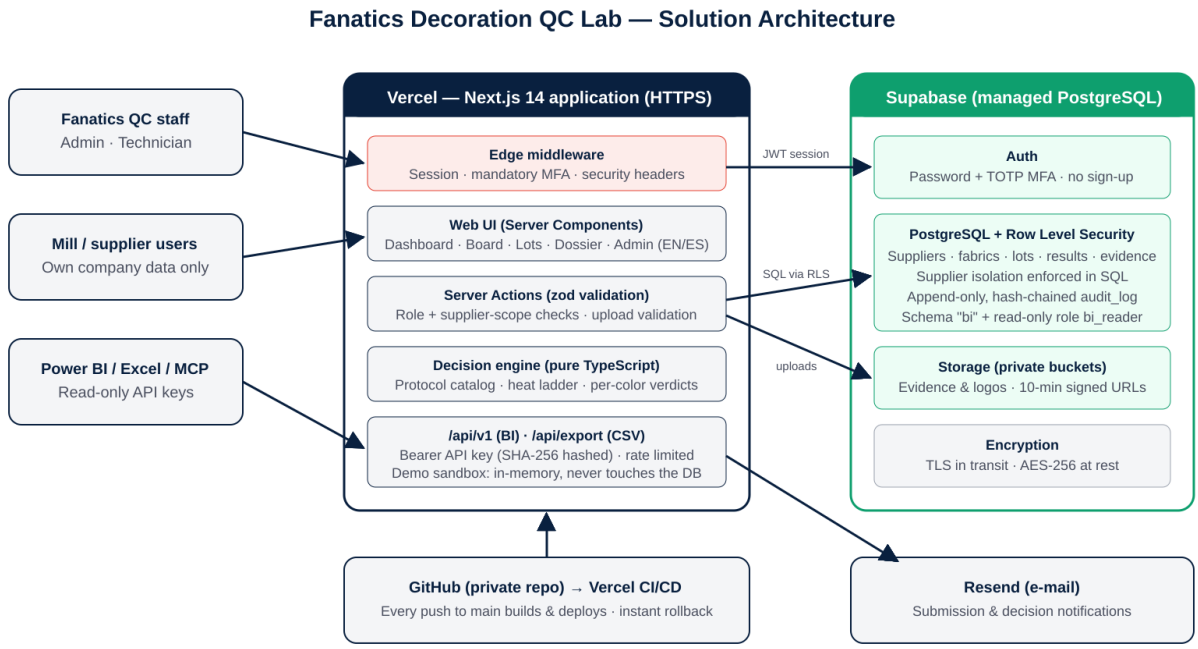
2.3 Permission matrix

Action	Admin	Technician	Supplier
View dashboards, lots, dossiers	All	All	Own company
Register fabrics / submit lots	Yes	Yes	Own company

Action	Admin	Technician	Supplier
Add / delete test results and evidence	Yes	Yes	Own, until decided
Move lots on the board, record decisions, override verdicts	Yes	Yes	No
Create / edit suppliers	Yes	No	No
Edit protocol minimums (requirements matrix)	Yes	No	No
Create / disable users	Yes	No	No
Audit log, API keys, sample data	Yes	No	No

These permissions are enforced three times: in the database (Row Level Security), in the server actions and in the user interface.

3. Solution architecture



3.1 Components

Component	Technology	Responsibility
Web application	Next.js 14 (App Router, React Server Components, Server Actions), TypeScript strict, Tailwind CSS	User interface (English/Spanish), server-side rendering, form handling. No business data is cached in the browser.
Edge middleware	Next.js middleware	Refreshes the session, enforces MFA (AAL2) on every request, redirects unauthenticated users, applies the demo/real mode toggle.
Decision engine	Pure TypeScript functions (`lib/domain/engine.ts`)	Deterministic evaluation of readings against requirements; unit-tested; no side effects.
Protocol catalog	`lib/domain/catalog.ts` → `supabase/seed.sql`	Single source of truth for 26 test methods, 16 decoration methods, 8 fiber families and default minimums.
Database	Supabase PostgreSQL 15+	All business data, Row Level Security, triggers, audit chain, BI views.
Authentication	Supabase Auth (GoTrue)	Password hashing (bcrypt), JWT sessions in HttpOnly cookies, TOTP MFA.
File storage	Supabase Storage (S3-compatible), private buckets	Evidence (photos, PDF reports, spectro files) and supplier logos.
E-mail	Resend (optional)	Notifications on submission and decision.
CI/CD	GitHub (private) → Vercel	Every push to `main` is built and deployed; previous deployments can be restored instantly.
Integrations	`/api/v1` REST, SQL schema `bi`,	Read-only access for Power BI, Excel, data warehouse and

Component	Technology	Responsibility
	MCP server (`mcp/`)	AI agents.
Mobile & push	PWA (manifest, service worker), Web Push (VAPID), Capacitor	Installable app, offline page, push notifications for submissions, decisions and CAPA.

3.2 Request flow

- The browser connects over HTTPS (TLS 1.2+, HSTS) to Vercel. The middleware validates the Supabase session cookie and requires an AAL2 (MFA-verified) session.
- Pages and server actions run on the server and query PostgreSQL **with the user's own JWT**, so Row Level Security applies to every query.
- The privileged service-role key is used only server-side for four operations: creating/disabling accounts (admin only), inserting notifications for other users, verifying API keys, and producing the read-only BI snapshot.
- Files are uploaded through the server (validated) into private buckets and served back with signed URLs that expire after 10 minutes.

3.3 Operating modes

Mode	How it is selected	Behaviour
Real system	Supabase environment variables configured (default)	Real accounts, MFA, data stored permanently in PostgreSQL.
Demo sandbox	"Explore demo" on the login screen (cookie `fx_mode=demo`), or no Supabase variables, or `DEMO_MODE=true`	One-click demo users and synthetic sample data held in server memory. It never reads or writes the real database and resets automatically.

> The demo toggle can be disabled in production by setting the environment variable `DEMO_SWITCH=false`.

4. Technology providers and accounts

All accounts are registered to the project owner's e-mail (djherreralopez95@gmail.com) and can be transferred to Fanatics-owned organizations (see section 13).

Provider	Use	Data held	Security / compliance (provider-published)	Plan today → recommended
Vercel	Hosting, CI/CD, TLS certificates, CDN	Application code, build logs, runtime logs, environment variables (encrypted)	SOC 2 Type 2, ISO 27001; automatic HTTPS; DDoS mitigation	Hobby → **Pro** (Hobby is for non-commercial use)
Supabase	PostgreSQL, Auth, Storage	All business data, user accounts, evidence files	SOC 2 Type 2; AES-256 encryption at rest; TLS in transit; daily backups on paid plans	Free → **Pro** (backups, no auto-pause, Point-in-Time Recovery add-on)
GitHub	Source code repository	Source code, history	SOC 2; 2FA; branch protection	Free private repo → Fanatics GitHub organization
Browser push services	Delivery of web push (Google FCM, Apple, Mozilla, Microsoft)	Encrypted push payload (title, short text, link) in transit only	Payload end-to-end encrypted per RFC 8291	No account needed
Resend	Transactional e-mail (optional)	Recipient e-mail, subject, notification text	SOC 2 Type 2	Free → Pro, or replace with Fanatics SMTP

> Provider certifications are as published by each vendor; Fanatics IT should obtain current reports through each vendor's trust portal. Database region: as selected for project `sncoqimwajlzxqikcghj` (US East recommended).

5. Data model and data classification

5.1 Tables

Table	Content	Classification
suppliers	Mill name, code, country, city, contact, tier, logo path	Internal
profiles	User id, e-mail, full name, role, supplier link, active flag	Internal — personal (work contact data)
fabrics	Article code, fiber, composition, construction, weight, shade, photo path	Internal — supplier confidential
lots	Lot, PO, program, garment, colors, methods, status, decision, overrides	Internal — supplier confidential
test_results	Test id, color, readings (JSON), assessment method, ΔE, lab, date	Internal — supplier confidential
evidence	File name, type, size, SHA-256, storage path, uploader	Internal — supplier confidential
lot_events	Timeline of each lot (who did what and when)	Internal
notifications	In-app notifications per user	Internal
requirements	Minimum grade / max value per fiber, test and reading	Internal
test_methods, decoration_methods, decoration_method_tests	Protocol reference data	Internal
garment_trials	Finished-garment wash trials: method, placement, cycles, grades, before/after photo links	Internal — supplier confidential
capas	Corrective & preventive actions: problem, root cause, containment, actions, due date, review	Internal — supplier confidential
push_subscriptions	Browser push endpoint and public keys per user device (no message content)	Internal
api_keys	Key name, prefix, SHA-256 hash (never the key), last use, revoked	Restricted
audit_log	Append-only change history with hash chain	Restricted

5.2 Personal data

The only personal data stored are the **names and work e-mail addresses** of system users (Fanatics staff and mill quality contacts) and their activity in the audit log. Passwords are never stored by the application (Supabase stores bcrypt hashes). No consumer, payment, health or government-ID data is processed.

5.3 Storage buckets

Bucket	Access	Limits
evidence (private)	Read/write only within the user's supplier folder (`<supplier_id>/…`); Fanatics staff read all; delete: admin only	10 MB per file; JPEG, PNG, WEBP, PDF, CSV, spectrophotometer exports

Bucket	Access	Limits
logos (private)	Read: signed-in users; write: admin only	2 MB; JPEG, PNG, WEBP

5.4 Retention

Recommended: keep lots, results and evidence for 7 years (typical QA record retention), then archive. Disabled users are retained (deactivated, not deleted) so that the audit trail remains complete.

6. Security controls

Security is applied in three independent layers so that a defect in one layer does not expose data: (1) the **database** (authoritative), (2) the **server**, (3) the **edge/browser**.

6.1 Identity and authentication

Control	Implementation
Account creation	Public sign-up disabled. Only the QC Administrator creates accounts (Users & access).
Passwords	Minimum 12 characters, upper and lower case, digit and symbol; rejects common words and the user's e-mail. Temporary passwords are random (16 characters, cryptographic RNG), shown once, and must be changed at first sign-in.
Multi-factor	TOTP (Google/Microsoft Authenticator, 1Password, Authy) mandatory for every account (`MFA_REQUIRED=true`). Every page requires an MFA-verified (AAL2) session.
Brute force	Supabase Auth rate limits plus application limits: 10 attempts per 15 minutes per IP and 5 per e-mail.
Sessions	JWT in HttpOnly, SameSite cookies; refreshed by the middleware; sign-out revokes the session.
Deprovisioning	Disabling a user blocks database access immediately (RLS) and bans the auth account so refresh tokens stop working.

6.2 Authorization and tenant isolation

- Row Level Security is enabled on **every** table; anonymous users have no table privileges.
- Helper functions `is_staff()`, `is_admin()`, `my_supplier_id()` and `can_see_supplier()` drive all policies.
- `supplier_id` on child records (results, evidence, events) is **set by database triggers** from the lot, so it cannot be forged by the client.
- Lots created by suppliers are forced to status `submitted` with no decision fields; only Fanatics staff can change status or decisions.
- Storage policies restrict each supplier to its own folder; a trigger also verifies the evidence path.
- Requests for another supplier's records return **404 Not Found** (no disclosure that the record exists).

6.3 Application security

Risk (OWASP Top 10 2021)	Mitigation
A01 Broken access control	RLS + server-side role/scope checks + middleware; UUID identifiers; 404 on foreign records.
A02 Cryptographic failures	TLS only with HSTS preload; secrets only in server environment variables; API keys stored as SHA-256 hashes.
A03 Injection	Parameterised queries (PostgREST); zod schema validation on every server action; React output escaping; CSV formula-injection neutralised.
A04 Insecure design	Separation of duties (suppliers submit, Fanatics decides); deterministic, unit-tested decision engine; overrides require staff role and are audited.
A05 Security misconfiguration	Content-Security-Policy (`default-src 'self'`, `frame-ancestors`

Risk (OWASP Top 10 2021)	Mitigation
	`'none'`, `object-src 'none'`), X-Frame-Options DENY, nosniff, Referrer-Policy, Permissions-Policy, framework banner removed, search-engine indexing disabled.
A06 Vulnerable components	Pinned dependency versions with lockfile; GitHub Dependabot recommended.
A07 Identification & authentication failures	Mandatory MFA, password policy, rate limiting, session refresh, account ban on disable.
A08 Software & data integrity	Hash-chained audit log; SHA-256 fingerprint of every evidence file; protected main branch; reproducible builds.
A09 Logging & monitoring	Audit log + Supabase Auth logs + Vercel runtime logs.
A10 SSRF	The server never fetches user-supplied URLs.

6.4 File upload controls

- File type is verified by **content signature (magic bytes)**, not by the declared type or extension.
- Maximum 10 MB; SVG and executable formats are rejected (cross-site-scripting vector).
- Each file receives a SHA-256 fingerprint stored with the record (chain of custody for lab evidence).

6.5 Secrets management

Secret	Location	Used for
SUPABASE_SERVICE_ROLE_KEY	Vercel environment (server only, encrypted)	Account creation/disable, cross-user notifications, API-key verification, BI snapshot
NEXT_PUBLIC_SUPABASE_ANON_KEY	Vercel environment (public by design)	Browser/server client; all access still governed by RLS
RESEND_API_KEY	Vercel environment	Sending notifications
API keys (fxqc_…)	Only SHA-256 hash in the database; shown once at creation	Power BI / integrations
bi_reader password	Set by the database administrator	Direct read-only SQL access to schema bi

Rotation: at least yearly, and immediately when a person with access leaves or a leak is suspected (procedure in section 11).

7. Audit trail and evidence

7.1 What is logged

- Every insert, update and delete on suppliers, profiles, fabrics, lots, test_results, evidence, requirements and api_keys: **who** (user id and e-mail), **when**, **what** (table, record) and, for updates, **each changed column with old and new value**. Secrets are stripped.
- Lot timeline (`lot_events`): creation, submission, results, evidence, status changes and decisions with comments.
- Authentication events: Supabase Auth logs. HTTP/runtime events: Vercel logs.

7.2 Tamper evidence

The `audit_log` table is **append-only**: a trigger rejects any UPDATE or DELETE (even by the database owner) and no access policy allows writes from the application. Each row stores `row_hash = SHA-256(previous_hash | row content)`, forming a chain; altering or removing any row breaks the chain.

Verification (Supabase → SQL Editor, or as an application admin):

```
select verify_audit_chain();   -- returns NULL when the chain is intact,
                                -- otherwise the id of the first broken row
```

7.3 Audit queries

```
-- RLS enabled on every table
select relname, relrowsecurity from pg_class c join pg_namespace n on n.oid =
c.relnamespace
 where n.nspname = 'public' and c.relkind = 'r' order by 1;

-- All access policies
select schemaname, tablename, policyname, cmd from pg_policies
 where schemaname in ('public','storage') order by 2, 3;

-- Users, roles and status
select email, role, supplier_id, active, created_at from profiles order by role, email;

-- Latest changes
select at, actor_email, action, entity_id, details from audit_log order by id desc
limit 100;

-- Decisions per lot
select ref, status, decided_by, decided_at, decision_notes from lots where decided_at
is not null;
```

The application also offers **Audit log** (screen and CSV export) and **Lots → CSV export** for auditors.

8. Quality protocol and decision engine

The protocol is defined in one file (`lib/domain/catalog.ts`) and mirrored to the database (`supabase/seed.sql`). Minimum values per fiber family can be adjusted by the QC Administrator in **Protocols → Requirements matrix**; each change is audited.

8.1 Test methods (26)

Category	Methods
Heat & migration	FX-DM-01 dye-migration heat ladder 130–210 °C · FX-DM-00 quick press screen (160 °C / 30 s) · ISO 105-P01 dry heat/sublimation · AATCC 133 hot pressing · AATCC 163 dye transfer in storage
Colorfastness	AATCC 61-2A laundering · AATCC 8 crocking · AATCC 15 perspiration · AATCC 107 water · AATCC 16.3 light · FX-CB-03 color-blocking bleed
Decoration performance	ASTM D3359-B adhesion · FX-WD-25 wash durability (25 cycles) · ASTM D2594-P stretch & recovery · ASTM D903-T peel strength · FX-PM-02 heat tolerance · FX-PT-05 DTG pretreatment & cure
Physical	AATCC 135 dimensional change · AATCC 179 skew · ASTM D3512 pilling · ASTM D3939 snagging · ASTM D3786 bursting strength
Shade & chemical	AATCC EP6/173 ΔE CMC vs standard · AATCC 81 pH · AATCC 112 formaldehyde · CPSIA lead in coatings

8.2 Decision rules

1. Grades 1–5 in half steps (5 = no change / no staining). Spectrophotometer ΔE values are converted to grades with the AATCC EP7/EP12 nominal table.
2. **Max safe decoration temperature** = highest heat-ladder temperature that still meets the minimum, continuously from the lowest step.
3. Per decoration method: passes at process temperature → approved; passes only at a lower, low-cure temperature → **conditional** with a temperature cap; bleeds below that but within one grade of the minimum → **conditional** with bleed blocker / poly white / blocker adhesive; otherwise not approved (critical test) or concession (non-critical).
4. Per color: each colorway is evaluated with its own results; the lot takes the **worst color**.
5. Suggested lot status: retest/rejected on critical failures, in review while tests are pending, approved with concession when conditions apply, otherwise approved. The final decision is always made by Fanatics staff.

8.3 Finished-garment wash trial

Minimums: overall appearance, cracking and peeling ≥ 4; fading ≥ 3.5; shrinkage ≤ 5 %. One minor miss → the method becomes **conditional (concession)**; a severe result (≤ 2.5) or several misses → the method is **not approved** for that lot (unless staff override with justification). Before and after photos are stored as evidence with SHA-256 fingerprints.

8.4 CAPA workflow

Step	Who	System behaviour
Open	Automatic on Rejected / Retest (or staff)	Problem statement generated from failing tests; due date +14 days; mill notified
Respond	Mill	Root cause, containment, corrective and preventive actions (simplified 8D); submit
Review	Fanatics	Accept, or return with notes (mill edits again)
Verify	Mill + Fanatics	Retest lot linked automatically; when approved, the CAPA closes automatically

Database rule `capa_supplier_guard`: suppliers can only edit their sections while the CAPA is open/returned and can only move it to submitted; they cannot change the problem, due date, review notes, links or close it. Overdue CAPAs are flagged on screen and in `bi.capas`.

> Default minimums are industry-typical starting points and must be validated by Fanatics QC against the Fanatics vendor manual before production use.

9. Integrations

9.1 Read-only REST API

Endpoint	Content
GET /api/v1/kpis	KPI snapshot (lots, RFT %, approval %, cycle time, average grade)
GET /api/v1/suppliers	Supplier scorecard
GET /api/v1/lots	Lots with status, max safe temperature, verdict per decoration method
GET /api/v1/colors	One row per lot × color
GET /api/v1/results	One row per reading with min, max and pass/fail
GET /api/v1/protocol	Test methods and default minimums

Authentication: `Authorization: Bearer fxqc_…` (keys created by the admin in **BI & API**, shown once, stored hashed, revocable, last-use tracked). `?format=csv` for CSV. Rate limit: 120 requests per minute per IP.

9.2 Direct SQL (Power BI PostgreSQL connector)

Schema `bi` exposes flattened views (`bi.lots`, `bi.test_readings`, `bi.supplier_scorecard`, `bi.suppliers`, `bi.fabrics`). The dedicated login `bi_reader` can only SELECT from schema `bi` and has no access to base tables.

9.3 Mobile app and push notifications

- The portal is an installable **Progressive Web App** (Android, iOS 16.4+, Windows/macOS) with its own icon, full-screen mode and an offline page. Authenticated pages are never cached on the device.
- **Web Push** uses the VAPID standard (`web-push` library). Each device subscription (endpoint + public keys) is stored per user under RLS; payloads contain only a title, short text and an in-app link — no test data. Expired subscriptions are removed automatically. Keys: `NEXT_PUBLIC_VAPID_PUBLIC_KEY`, `VAPID_PRIVATE_KEY` (server only).
- A **Capacitor** wrapper (`mobile/`) packages the hosted site for Google Play / App Store if required; native push would use FCM / APNs.

9.4 MCP server (AI agents)

`mcp/server.mjs` is a read-only Model Context Protocol server that wraps the REST API with its own API key. It exposes six read-only tools (KPIs, scorecard, lots, lot detail, failing tests, protocol) and cannot modify data.

10. Testing and quality assurance

Test	Scope	Result
Static analysis	TypeScript strict type-check, ESLint (Next.js rules)	No errors
Unit tests (17)	ΔE conversion, heat ladder, method verdicts, fiber-specific minimums, overrides, per-color worst case, critical failures, garment-trial rules, CAPA state machine and overdue logic, CSV injection, password policy	17/17 pass
Database security tests	On PostgreSQL 16: supplier A cannot read, insert or upload into supplier B; cannot approve its own lot; cannot open, close or alter Fanatics fields of a CAPA, nor edit it after submitting; cannot see other users' push subscriptions; audit log immutable; audit chain verifies; schema re-runnable	Pass
End-to-end tests (browser)	Supplier creates lot with colors, adds results with photo; supplier isolation (404 / 403 / redirects); admin decision; notifications; API key valid → 200, invalid → 401; Spanish UI; demo/real toggle; garment trial with before/after photos → rejection → automatic CAPA → mill submits → Fanatics accepts → retest linked → retest approved → CAPA closed; service worker, manifest and offline page	Pass
Production build	Next.js optimized build	Pass

Commands: `npm run typecheck`, `npm run lint`, `npm test`, `npm run build`. SQL tests are in `supabase/tests/`.

10.1 Development approach

The MVP was developed with AI-assisted software development tools (Anthropic Claude). All code is in the repository for review and is covered by the automated tests above. An independent code review and a third-party penetration test are recommended before production use with real supplier data.

11. Operations

11.1 Deployment

1. Changes are committed to the private GitHub repository (`main` branch, protected).
2. Vercel builds and deploys automatically; failed builds never replace the live version.
3. Rollback: Vercel → Deployments → previous deployment → Promote / Instant Rollback.
4. Database changes: `supabase/schema.sql` is idempotent; apply through the Supabase SQL Editor after testing on a scratch database.

11.2 Environment variables

Variable	Purpose
NEXT_PUBLIC_SUPABASE_URL / NEXT_PUBLIC_SUPABASE_ANON_KEY	Connection to Supabase (governed by RLS)
SUPABASE_SERVICE_ROLE_KEY	Server-only privileged key (see 6.5)
NEXT_PUBLIC_APP_URL	Public URL used in e-mail links
MFA_REQUIRED	true = mandatory TOTP for every account
DEMO_SWITCH	false = hide the demo sandbox in production
NEXT_PUBLIC_VAPID_PUBLIC_KEY / VAPID_PRIVATE_KEY / VAPID_SUBJECT	Web push notifications (private key is server-only)
RESEND_API_KEY / RESEND_FROM_EMAIL	E-mail notifications (optional)

11.3 Access reviews and onboarding / offboarding

- Quarterly: export **Users & access**, confirm each supplier user still works for that mill; disable leavers.
- Offboarding: disable the user (immediate), revoke API keys they created, rotate shared secrets if they had access to them.

11.4 Backups and recovery

- Supabase Pro: daily backups (7-day retention); enable Point-in-Time Recovery for production.
- Source code: GitHub history; deployments: Vercel history with instant rollback.

11.5 Incident response

1. **Contain** — disable affected users, revoke API keys, rotate the service-role key in Supabase and update Vercel.
2. **Assess** — run `verify_audit_chain()`, export the audit log, review Supabase Auth and Vercel logs.
3. **Recover** — patch and redeploy (or roll back); restore from backup/PITR if data was altered.
4. **Notify** — Fanatics Information Security within the required window; document timeline and root cause.

12. Known limitations and risk register

#	Item	Risk	Recommended action
1	Vercel Hobby and Supabase Free plans	Hobby is for non-commercial use; Free projects pause after inactivity and have no backup guarantees	Upgrade to Vercel Pro and Supabase Pro (or move to Fanatics accounts) before production
2	No SSO	Separate credentials for Fanatics staff	Enable SAML SSO (Okta / Azure AD) — supported by Supabase Pro
3	In-memory rate limiter	Limits are per server instance	Add Vercel Firewall / WAF rules for /login and /api
4	CSP allows inline scripts	Required by the framework's hydration	Move to nonce-based CSP in a later release
5	Not yet penetration-tested	Unknown residual vulnerabilities	Third-party pentest before go-live
6	Default protocol minimums	May differ from the Fanatics vendor manual	QC validation of the requirements matrix
7	Demo sandbox on the login screen	Visitors may confuse demo data with real data	Clearly labelled; set DEMO_SWITCH=false when not needed
8	E-mail domain not verified	Notifications only in-app until a domain is verified	Verify a Fanatics domain in Resend or use corporate SMTP
9	Mill logos are placeholders	Cosmetic	Upload official logos (Suppliers → Edit)

13. Ownership transfer to Fanatics IT

Asset	Transfer method
GitHub repository	Settings → Transfer ownership → Fanatics GitHub organization
Vercel project	Project Settings → Transfer project → Fanatics team (or re-import the transferred repository)
Supabase project	Invite Fanatics owners to the organization, or Project Settings → Transfer project
Domain	Add a Fanatics subdomain (e.g. qclab.fanatics.com) in Vercel → Domains
E-mail	Resend team members or replacement with Fanatics SMTP

After transfer: rotate the service-role key, revoke and reissue API keys, change the `bi_reader` password, disable temporary administrators and record the audit-chain baseline with `verify_audit_chain()`.

14. Production readiness checklist and roadmap

14.1 Checklist

☐ Paid plans (Vercel Pro, Supabase Pro) or Fanatics-owned accounts
☐ Public sign-up disabled; TOTP enabled; MFA_REQUIRED=true
☐ Site URL and redirect URLs set in Supabase Auth
☐ Requirements matrix validated by Fanatics QC
☐ Official supplier logos and data loaded; sample data removed
☐ Users created with least privilege; quarterly access review scheduled
☐ Backups / Point-in-Time Recovery enabled
☐ Penetration test completed and findings remediated
☐ DEMO_SWITCH=false if the demo sandbox is not wanted in production
☐ Audit-chain baseline recorded

14.2 Roadmap

- SSO for Fanatics staff (Okta / Azure AD).
- Automatic import of Datacolor / X-Rite spectrophotometer files into ΔE readings.
- Native push for store builds (Firebase Cloud Messaging / APNs).

Appendix A — Repository map

Path	Content
app/	Pages, API routes, middleware entry points
components/	User-interface components (dossier, charts, forms, Kanban board)
lib/domain/	Protocol catalog, decision engine, types
lib/data/	Data-access layer (Supabase and demo implementations)
lib/actions/	Server actions with validation
supabase/	schema.sql, seed.sql, suppliers.sql, first-admin.sql, tests/
mcp/	Read-only MCP server
mobile/	Capacitor wrapper for Android / iOS store builds
docs/	Setup (EN/ES), security, protocols, Power BI, MCP, handoff
CLAUDE.md	Engineering guide for maintainers and AI coding assistants